

LEZIONE 01

Cosa stai proteggendo, e da cosa

Prima di parlare di firewall e antivirus conviene mettersi d'accordo su quattro parole. Le uso in tutte le lezioni, e le sento confondere in quasi tutte le aziende.



1 di 12

A COLPO D'OCCHIO

C

Riservatezza

Solo chi è autorizzato legge l'informazione.

La viola: un furto di dati

I

Integrità

Nessuno altera l'informazione senza permesso.

La viola: un ransomware

A

Disponibilità

Il servizio risponde quando serve.

La viola: un guasto, un DDoS

Rischio = **probabilità** × **impatto**. La vulnerabilità è la porta aperta, l'exploit è chi ci passa.

La sicurezza in tre parole: la triade CIA

Ogni misura di sicurezza serve a proteggere almeno una di **tre** proprietà:

- **C — Confidentiality (Riservatezza):** solo chi è autorizzato accede all'informazione. *Esempio:* cifratura del disco, permessi sui file, HTTPS.
- **I — Integrity (Integrità):** l'informazione non viene alterata senza autorizzazione. *Esempio:* hash/checksum, firme digitali, log append-only.
- **A — Availability (Disponibilità):** il servizio è raggiungibile quando serve. *Esempio:* ridondanza, backup, protezione anti-DDoS.

Un attacco si può leggere sempre come **violazione** di C, I o A: un furto di dati viola C; un ransomware viola I e A; un DDoS viola A.

Il vocabolario del rischio

Quattro parole che spesso si confondono:

Termine	Significato	Esempio
Minaccia (threat)	<i>chi/cosa</i> potrebbe farti danno	un gruppo ransomware
Vulnerabilità	una <i>debolezza</i> sfruttabile	un software non aggiornato
Exploit	il <i>codice/tecnica</i> che sfrutta la vulnerabilità	il programma che attiva il bug
Rischio	probabilità × impatto	quanto è probabile e quanto farebbe male

Vulnerabilità ≠ exploit: la vulnerabilità è la *porta aperta*, l'exploit è *passarci attraverso*.

Zero-day: una vulnerabilità **sfruttata prima** che sia nota al produttore o che esista una correzione (patch). È pericolosa perché non c'è ancora difesa ufficiale.

DA FARE

Lunedì mattina, se sei l'unico informatico

- 1** Scrivi su un foglio i cinque sistemi senza i quali l'azienda si ferma. Di solito sono gestionale, posta, file server, produzione e centralino. ☐
- 2** Per ognuno segna cosa conta di più: che nessuno lo legga, che nessuno lo modifichi, o che funzioni. Per il gestionale di solito è che funzioni, per le buste paga che nessuno le legga. ☐
- 3** Tieni il foglio: nelle prossime lezioni ti dice dove mettere il primo backup e il primo secondo fattore. ☐

Alessandro Manneschi

penetration test, NIS2 e monitoraggio per le piccole aziende

Tutte le lezioni, gratis:

github.com/alevento/sicurezza-per-chi-e-solo

Licenza CC BY-NC-SA 4.0